PatchBond

Refundable bonds for pull requests

A market for maintainer attention.

Refundable bonds for pull requests on NEAR. Real work gets every cent back. Unpaid PRs close themselves; a forfeited bond pays the maintainer — decided by AI anyone can verify.

EIP-1559 for open source

● Live: TEE-signed AI verdicts on NEAR AI Cloud

USDC or NEAR · live on NEAR testnet

github.com/PatchBond/patchbond

NEAR Hackathon 2026

THE PROBLEM — FROM THE MAINTAINER OF SANCTIFIER · 120+ CONTRIBUTORS · 570 PRS

“Some people just create tens of PRs resolving issues they weren't even assigned to — or claim a PR does what it doesn't do.”

The sender spends ten seconds; the maintainer spends an hour. **Nothing connects the two** — and AI made sending free.

~25%

of incoming PRs estimated to be low-quality AI output — 31% on larger projects.

Linux Foundation Research, Oct 2026

49

AI-slop security reports on curl's public list; curl moved low-severity reports public to cope.

curl maintainer's public list

PRs off

GitHub now lets repos turn PRs off, limit them to collaborators or cap them per outsider — shutting honest newcomers out too.

GitHub changelog, Feb & Jun 2026

Some are attacks

Rarely, an outside PR carries an install hook that runs a download or a poisoned workflow. PatchBond scans every added line for these.

e.g. the xz-utils backdoor, 2024

Sources: docs/RESEARCH.md

THE IDEA

Make wasting a maintainer's time cost something.

1 · Bond

Strangers attach a small refundable deposit

USDC or NEAR — each repo chooses. Maintainers, collaborators and proven contributors pay $0.

2 · Verifiable AI

A TEE model judges it after CI

Using facts we compute. The response is signed and public.

3 · Settle

Refund — or the repo is paid

Real work: every cent back. Slop: 90% to the repo's vault.

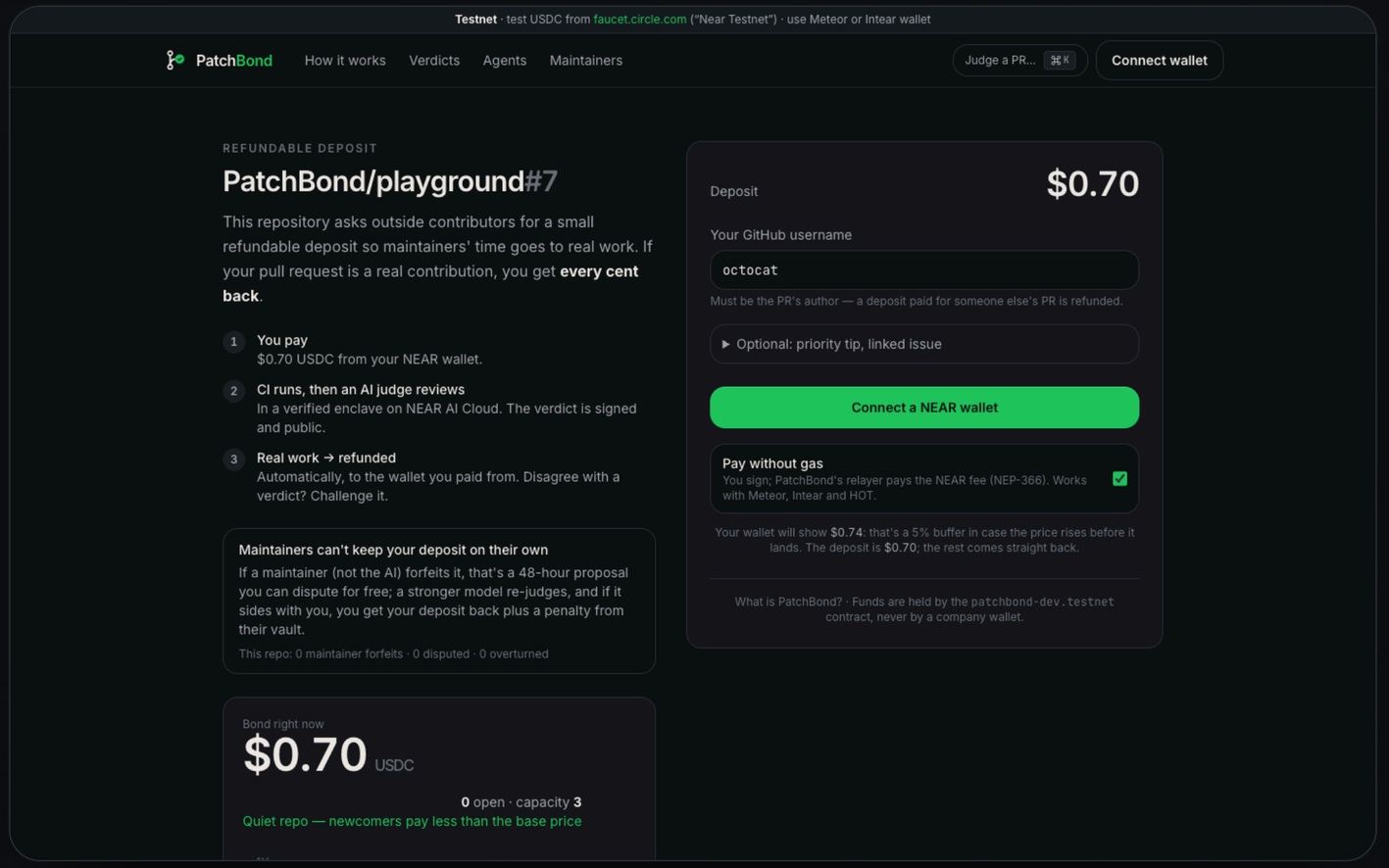
The bond sits in a NEAR contract — **never with us**; only the repo's linked payout account can withdraw. The opposite of tea.xyz: spam **costs** money instead of earning it. No token.

THE PRODUCT

One comment on the PR. One tap to pay.

The GitHub App asks strangers for a bond with the live price and a **24 h deadline**. They pay from any NEAR wallet — USDC **gasless** (NEP-366), or NEAR wrapped in the same transaction.

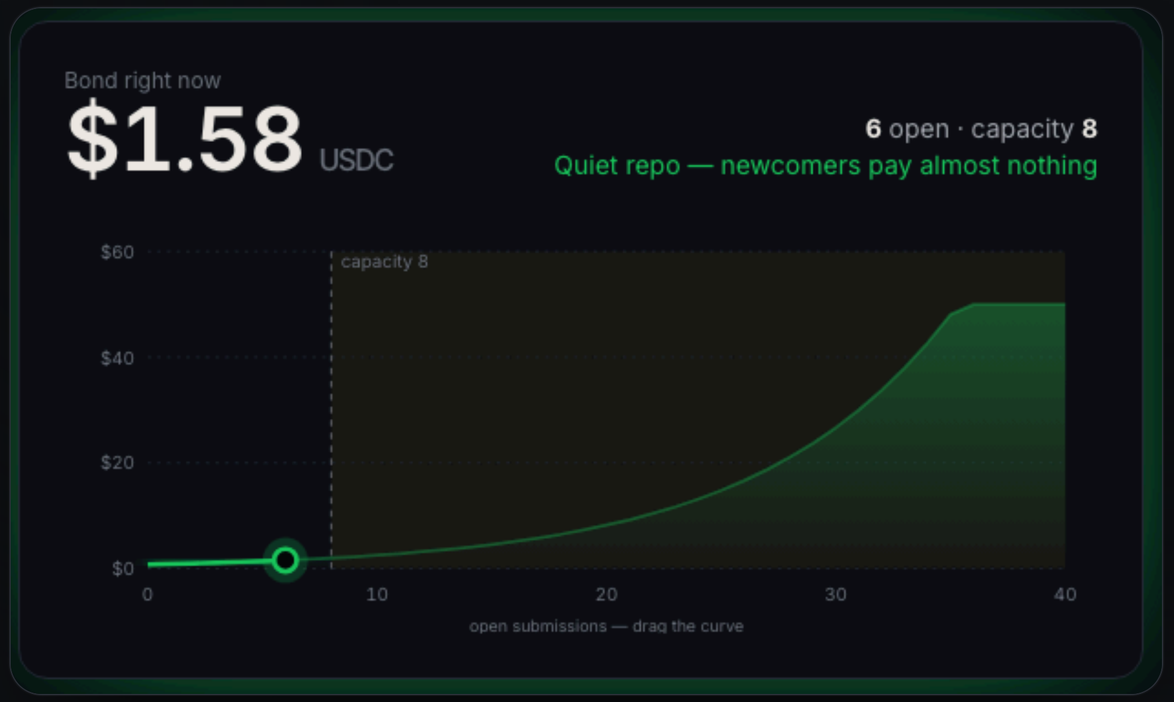
The maintainer gets a GitHub email when it's paid. After CI, the verdict lands on the PR as a check and a comment.



EDGE 1 · ATTENTION PRICING

EIP-1559 for maintainers.

The bond follows the repo's open queue — computed **on-chain** from unsettled deposits. Tens of PRs at once? Each one makes the next **12.5%** more expensive. A quiet repo costs a newcomer cents.



Quiet repo

6 open, capacity 8 → **$1.58**

Busy

14 open → **$4.05**

Spam wave

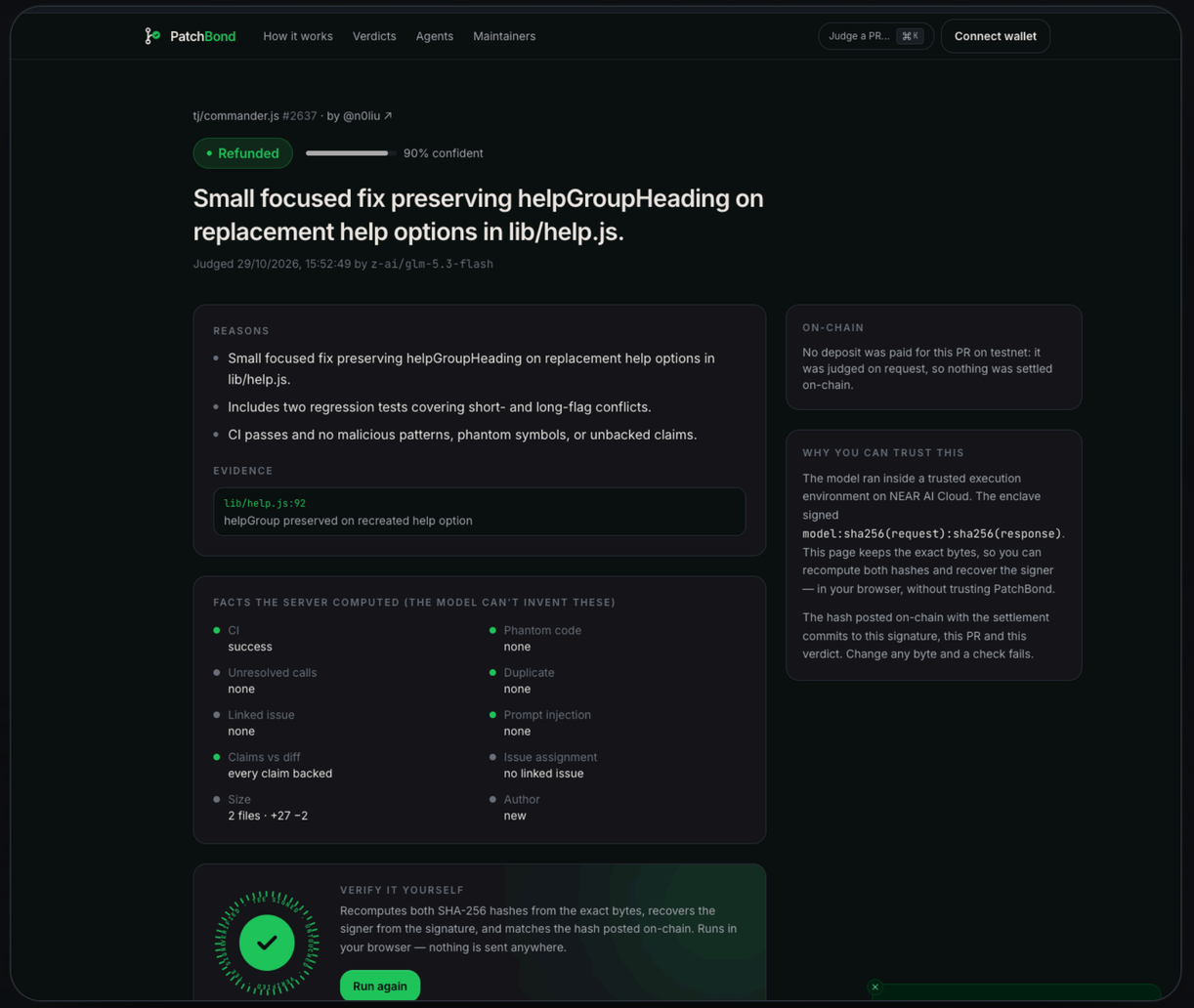
40 open → **$50 ceiling**

```
bond = clamp(min, max, base × 1.125^(open - capacity)) × reputation
```

Facts first. Then a verifiable model.

CI	The repo's own checks — we never run contributor code
Phantom code	Calls into the project's own namespace that don't exist
Claims vs diff	“Added tests”, “updated README” — is it in the diff?
Assignment	Was the issue assigned to someone else?
Injection	Text that tries to instruct the judge
Malicious code	Hidden Unicode, decoded-payload exec, curl | sh, secret exfiltration, poisoned workflows

A forfeit needs high confidence, evidence **and** a hard fact. When in doubt, refund.



Live: z-ai/glm-5.3-flash in a TEE · 0/15 good PRs forfeited · 14/15 refunded automatically · $0.00035 a verdict

DON'T TRUST US

Every verdict is checkable — and our server can leave the loop.

`sha256(request)` ✓

The exact bytes the model saw.

`sha256(response)` ✓

The exact answer, unedited.

`signer` ✓

NEAR AI's attested enclave key — checked in your browser.

`contract` ✓

ecrecover on-chain: **no forfeit without it**, not even from our server.

OutLayer · Intel TDX · live on testnet

A server that builds the prompt could feed the model false facts. With **judge_in_tee**, anyone asks the contract; an enclave runs our pinned program — it reads GitHub itself, asks NEAR AI, applies the same rules (byte-identical prompts on 30 real PRs) — and the contract checks NEAR AI's signature before it settles. `exclusive` mode removes the oracle's forfeit power entirely.

✓ tx GTZM613J… · 24.5 s in the enclave · 0.0036 NEAR · signer 0x3b75…fa0c recovered on-chain

shared/src/verify.ts · contract/vault/src/tee.rs · contract/vault/src/outlayer.rs · docs/OUTLAYER.md

JUDGE QUALITY

Built for precision: no honest work forfeited.

NEAR's own core repo · near/nearcore

186 open PRs

20 from strangers, judged

0 PRs forfeited

13 refunded automatically · 7 to a maintainer · **$0.0074 for all 20**, every verdict TEE-signed. Real fixes there wait a median **236 days** for review — signed triage helps even without spam.

0 / 15

labelled good PRs forfeited (0 of 20 on nearcore too). Honestly, the other side: 0 of 15 labelled slop forfeited by the AI — 8 went to a human. The bond stops spam first.

Forfeit · 0.99 · signed by NEAR AI · test PR we built

“Adds a postinstall hook that pipes a remote script into a shell… none of the claimed work: no tests, no src/queue.ts change.”

The contract accepts this signature on-chain — `bun run demo`

FAIR TO BOTH SIDES

Protects contributors, maintainers and the code.

Contributors protected

A maintainer can't keep your bond on their own

Their forfeit is a 48 h proposal you dispute **for free**. A stronger model re-judges. Overturned? You get your bond back **plus a penalty** from their vault — and it's on their public record.

Attacks caught

Malicious code is flagged before anyone reviews it

A deterministic scan finds Trojan-Source Unicode, hidden payloads, install-time downloads and poisoned CI, and proposes a forfeit. It settles on-chain only if the model signed a forfeit too — otherwise a maintainer confirms. No false alarms on 50 real PRs. None of them was malicious, so this shows it stays quiet — not yet that it catches real attacks.

Attention kept

Unpaid PRs cost nothing to ignore

Labelled `deposit paid` / `awaiting`, closed after an announced 24 h, reopened the moment they pay.

contract/vault/tests/maintainer_safeguards.rs · server/src/judge/malice.ts

NOT A SLOP FILTER — A MARKET

Four mechanisms, one NEAR contract.

Priority lane

Pay for attention, not for submitting

A review tip reaches the repo only if a maintainer reviews within the promised window — otherwise it's refunded.

Optimistic verdicts

Cheap AI by default, strong AI when money's on the line

Stake to challenge; a stronger model re-judges with both sides' statements; the loser's stake pays the winner.

Slop funds the fix

Spam pays whoever really fixes the issue

A forfeited PR that claimed to fix #N becomes a bounty on #N, paid when a real fix is merged.

Know your agent

Capped wallets for coding agents

A function-call key that can only pay bonds, under a daily cap the contract enforces; a public record per harness. On testnet, the bond over the cap was refused.

BUILT ON NEAR

Built on NEAR primitives.

NEAR AI Cloud	Live verifiable inference in a TEE (GLM-5.3-flash, Kimi K3); signatures checked in the browser **and by the contract**
OutLayer (Intel TDX)	The judge as a wasm program in an enclave, called by the contract (yield/resume); the callback checks NEAR AI's signature
Rust contract + NEP-297	Bonds, curve, verdicts, challenges, vaults, budgets, reputation
NEP-141 USDC & wNEAR	Bonds in USDC or NEAR — NEAR wrapped and paid in one signed transaction
Function-call keys	Capped agent wallets that can only pay bonds
Meta transactions (NEP-366)	Gasless bonds — our relayer pays the fee
NEP-413 signed messages	Maintainers prove wallet ownership to link a repo
NEAR Intents 1Click	Payout quotes to Base, Arbitrum, Ethereum or Solana (dry-run; the transfer runs on mainnet)
Sputnik DAO / Trezu	Hand a repo's vault to a project treasury

Paths to each in the README

PROOF, NOT PROMISES

Built, tested, and live.

62

real testnet transactions in one end-to-end run — each money path, gasless USDC, NEAR via the real wrap.testnet, an agent via MCP. All passed.

181

automated tests: 61 contract (incl. a 50,000-case money property test, genuine NEAR AI signatures verified on-chain, the OutLayer callback), 115 TypeScript, and byte-parity of the enclave judge on 30 real PRs.

0/15

labelled good PRs forfeited by the **live TEE judge** (plus 0 of 20 on nearcore's open queue). $0.00035 a verdict.

✓ curve on-chain = curve in the app · ✓ refund · 90/10 forfeit · void · ✓ slop funds the fix · ✓ challenge won after a real window · ✓ gasless bond: 0 NEAR spent · ✓ agent key can't escape its cap · ✓ NEAR bond: wrap + pay in one tx · ✓ a maintainer can't keep a bond alone · ✓ live test PR (paid from our own second wallet) on a 120+-contributor repo, judged in a TEE · ✓ a stolen oracle key can't redirect a vault — or fake a forfeit · ✓ judged inside OutLayer TDX on testnet · ✓ `bun run demo` : clone → refund & forfeit, one command

docs/e2e/testnet-report.md — one explorer link per tx · threat model in SECURITY.md

Make your repo's attention worth something.

Cheap to run

≈ $0.00035 a signed verdict — under $1 per 1,000 PRs. Hosting is one small server; the contract holds the money.

Paid by the right people

Never honest contributors, never for submitting. 10% of forfeits today; next: bug-bounty triage and organisations.

Maintainers

One repo, 10 minutes — `docs/MAINTAINERS.md`. Your team never pays.

Agent builders

The MCP server, and a wallet whose spending the contract caps.

NEAR

Verifiable AI deciding where real money goes, in public.

github.com/PatchBond/patchbond

MIT · No token